Nätverkssäkerhet

Föreläsning 6 – IDS/IPS

Planering

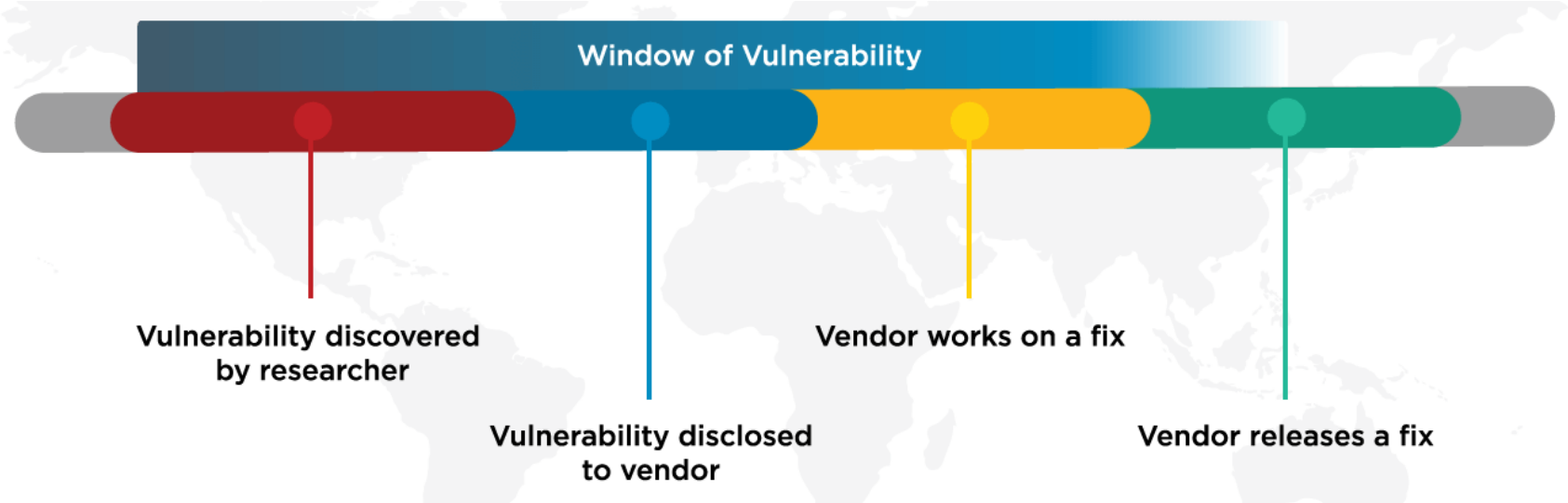
Vecka	Dag	Moment
35	Mån	~~**Föreläsning –** Kursintroduktion & introduktion till nätverkssäkerhet~~
	-	~~**Videoföreläsningar –** Säkra upp enheter & AAA~~
	Mån /Tis	~~**Laboration 1**~~
36	Mån	~~**Forts. Laboration 1**~~
	Tis	~~**Dugga 1** (09.00)~~
	Tor	~~**Gästföreläsning Fortinet**~~
	Fre	~~**Föreläsning –** Introduktion till brandväggar~~
37	Mån	~~**Laboration 2**~~
	Tis	~~**Dugga 2** (09.00)~~
	Tis	**Föreläsning** – IDS/IPS
38	Mån	**Laboration 3**
	Tis	**Dugga 3** (09.00)
	Tis	**Gästföreläsning JSC (09.30) & Föreläsning** – LAN- och endpoint-säkerhet
	Fre	**NFK-introduktion**
39	Mån	**Laboration 4**
	Tis	**Dugga 4** (09.00)
	-	**Videoföreläsning** – Kryptografi
	Tor	**Föreläsning** – VPN
40	Mån	**Laboration 5**
	Tis	**Dugga 5** (09.00)
	Tis	**Föreläsning** – Extrapass
41	Ons	**Laboration 6 & Redovisningar av Laboration 6**
42	-	**Tentavecka**

IDS och IPS (IDPS)

- **IDS – Intrusion Detection System**
  - Känner av intrång, loggar det, men stoppar det inte
- **IPS – Intrusion Prevention System**
  - Känner av intrång, stoppar skadliga paket innan det når enheter
  - IPS kan också ses som ”antivirus för nätverket”, men…
- Varför behövs det?
  - En brandvägg tar inte allt, och är inte byggd för att skydda mot attacker
  - Mer avancerade attacker (t.ex. zero-day)
- Ibland dedikerade enheter, och ibland inbakade i en brandvägg (NG)
- Finns både **nätverksbaserade** och **host-baserade**

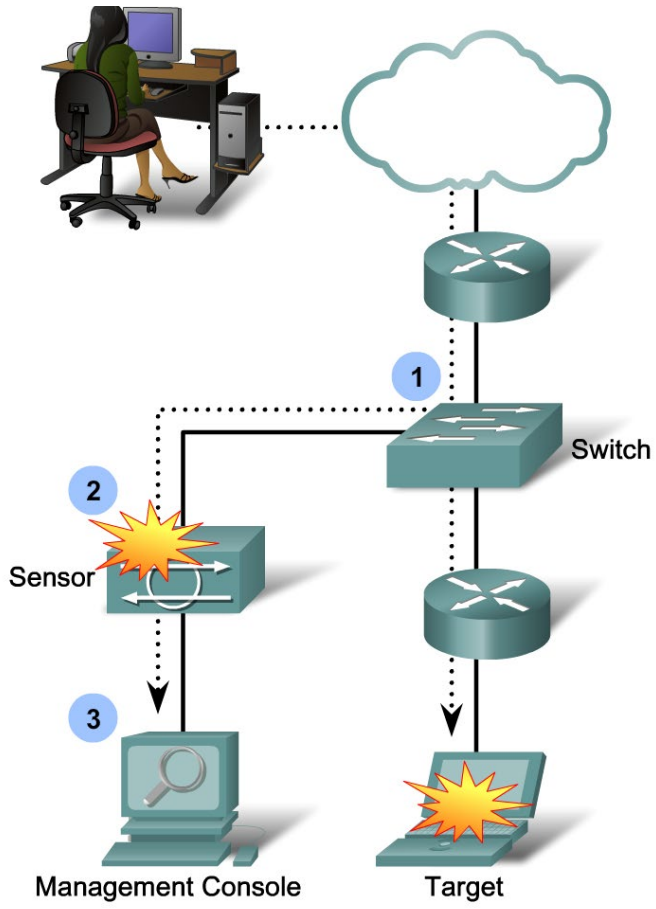
Zero-day vulnerabilites

- Okända sårbarheter som ännu inte känns igen av antivirus, brandväggar och enkla IDS/IPS-signaturer
- Vissa typer av IDS/IPS kan hjälpa till att skydda mot dessa (t.ex. *anomaly-based*)



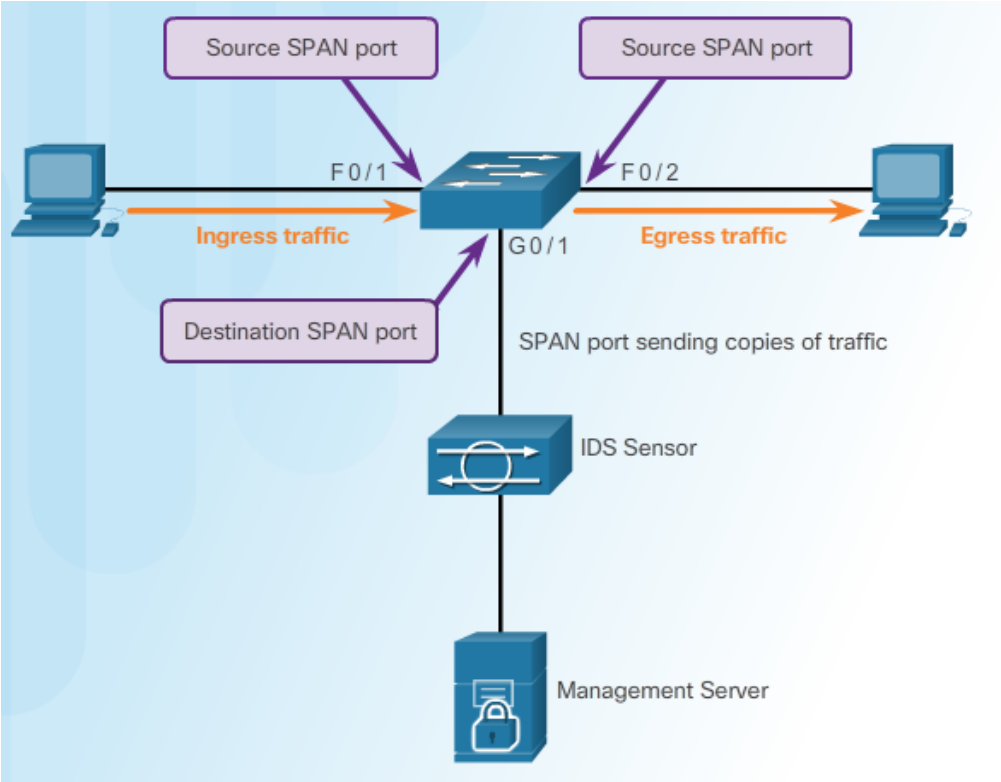
IDS – Intrusion Detection System

- Passiv enhet
  - Kan vara en switch med **SPAN** (*Switched Port ANalyzer*)
  - Påverkar inte trafikflödet eller prestanda i nätet
- Stoppar inga attacker, men loggar och larmar
  - Vissa gör även ändringar
- En IDS kan också kallas för ”IDS sensor” eller bara ”sensor”



Konfigurera SPAN

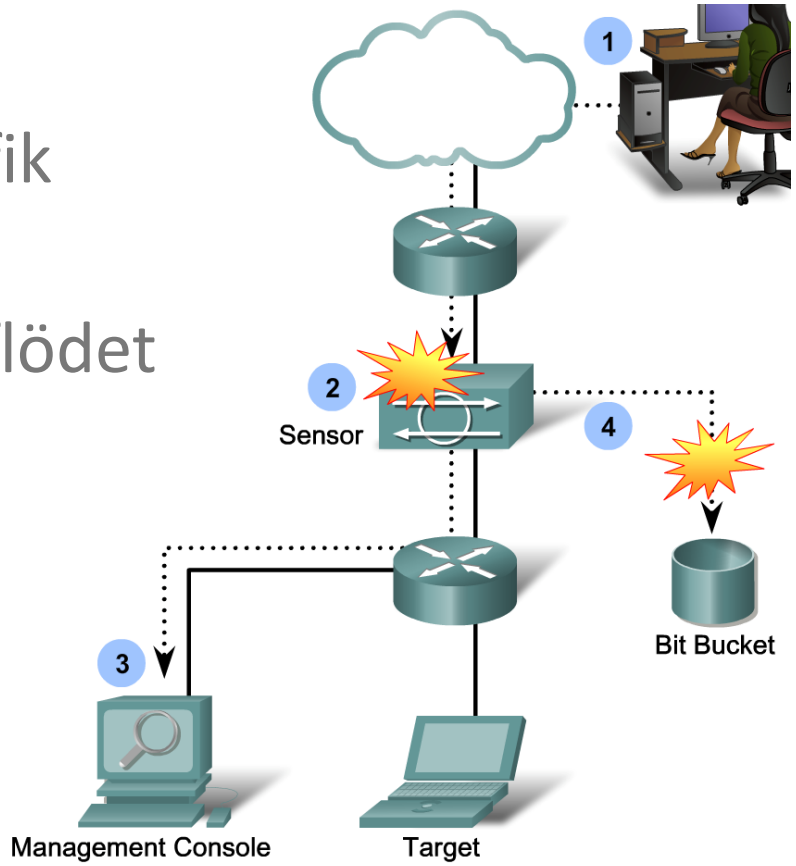
- Finns några olika varianter
  - **Local SPAN (SPAN)**
  - Remote SPAN (RSPAN)
  - VLAN-based SPAN (VSPAN)




```
Switch(config)# monitor session 1 source interface fa0/1 [both / rx / tx]
Switch(config)# monitor session 1 source interface fa0/2
Switch(config)# monitor session 1 destination interface gi0/1
```

IPS – Intrusion Prevention System

- Bygger på IDS
- Sitter *in-line* (aktiv enhet), kan därmed stoppa trafik
  - Kan därför påverka prestanda negativt
- Om den överbelastas kan det bli tvärstopp i trafikflödet
  - **Fail-open**
  - **Fail-close**
  - **Vilken lösning är bäst?**



Host-baserad IPS

- Host-baserad IPS är en IPS som implementeras hos klienten
- Ger skydd till ett visst operativsystem och skyddar på applikationsnivå
  - Ofta ett annat fokus än en Nätverks-IPS
- Skyddar även där Nätverks-IPS inte har blockerat (t.ex. krypterad trafik)
- **Nackdelar:**
  - Måste installeras på alla klienter
  - Programvaran skiljer beroende på operativsystem
  - Får inte ett helhetsgrepp om säkerheten i ett nätverk

Nätverks-baserad IPS

- IPS som appliceras i nätverket (vanligast!)
  - Tekniskt sett går det dock att köra en Nätverks-IPS även på en host
- En fördel med Nätverks-IPS är att den inte är beroende av vilket operativsystem som körs på klienterna
- För högsta säkerheten bör det finnas sensorer på flera ställen i nätverket
- Nätverks-IPS och Host-IPS bör båda användas för högsta säkerheten
- **Nackdelar:**
  - Skyddar inte i operativsystemet eller i en specifik applikation
  - Kan inte analysera krypterad trafik (om den inte kör SSL Inspection)

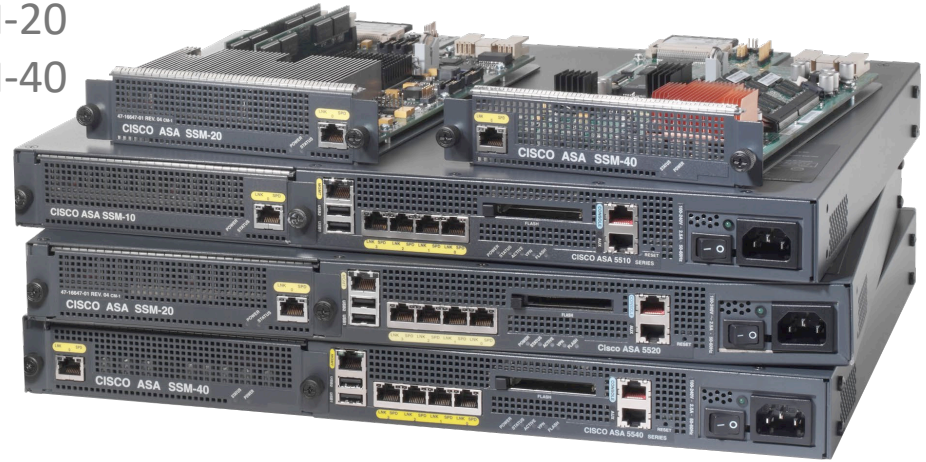
Nätverks-baserad IPS

- Kan implementeras som en egen enhet eller som tjänst…
  - På en Ciscos ISR-router (med eller utan en modul)
  - På en ASA (med eller utan en modul)
  - Som en egen enhet (t.ex. Cisco IPS 4300)
  - På en dator eller server (t.ex. med Snort)
  - Cisco Firepower (t.ex. 2120)
  - FortiGate

Cisco Firepower 2120

Cisco Catalyst 6500

AIP-SSM-10
AIP-SSM-20
AIP-SSM-40



Cisco IPS 4300

Cisco ASA AIP SSC-5

Cisco ISR 2901

Vad ska man välja?

- IDS vs. IPS vs. Nätverks-IPS vs. Host-IPS vs. Nätverks-IDS vs. Host-IDS
- Beror (bland annat) på följande faktorer:
  - Mängden nätverkstrafik
  - Nätverkstopologi
  - Budget
  - Tillgänglig IT-personal
  - Säkerhetskrav

Attack-signaturer

Terminologi enligt Cisco

Attack-signaturer

- En **signatur** är ett visst antal regler som förklarar en viss typ av skadlig trafik
- Om något matchar en signatur vet IDS/IPS att det är skadlig trafik
- En signatur har vissa attribut:
  - **Type** (Atomic vs. Composite)
  - **Trigger** (Signature trigger)
  - **Action** (Larm)

Signaturtyper (Type)

- Delas in i två olika:
- **Atomic signatures**
  - När IDS/IPS bara kollar skadlig trafik utifrån ett paket åt gången
  - Prestandaeffektivt eftersom systemet inte behöver komma ihåg en session
- **Composite signatures**
  - Att jämföra med ”**stateful**”
  - Kommer ihåg en session (states/lägen) och kan kolla flera paket i en *ström*
  - Tar mycket prestanda
    - …men kan finjusteras, beroende på hur länge den ska minnas

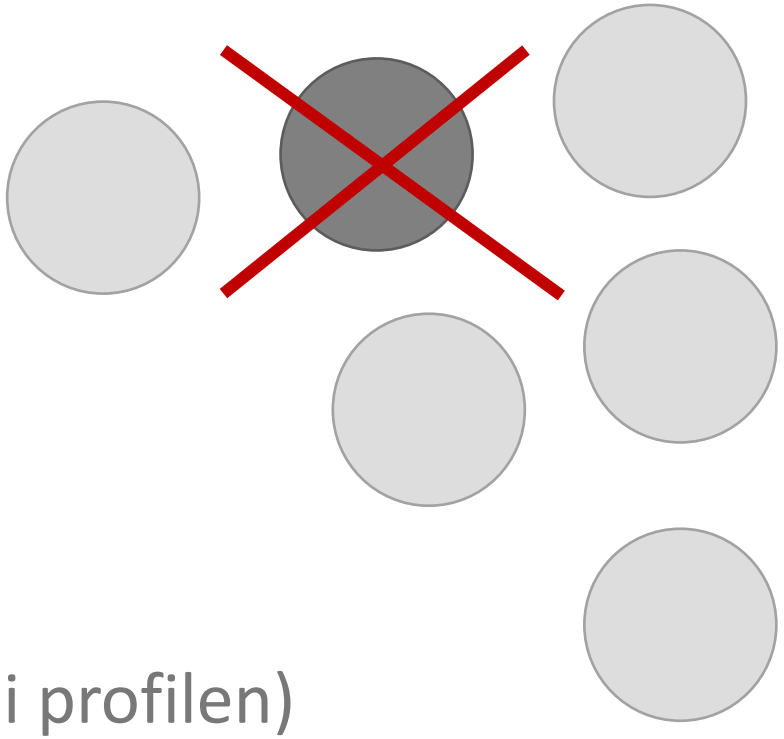
Signature trigger

- Finns fyra olika triggers som detekterar skadlig trafik:
  - Signature/pattern based
  - Anomaly based
  - Policy based
  - Honey pot based

Signature/pattern based

- Enklast möjliga trigger, matchar ett visst paket eller ett visst mönster av kända attacker
  - Enkla att konfigurera
  - Kräver mindre resurser
  - **Nackdel:** Matchar inte okända hot
- Kan även matcha enkla saker som textsträngar och liknande

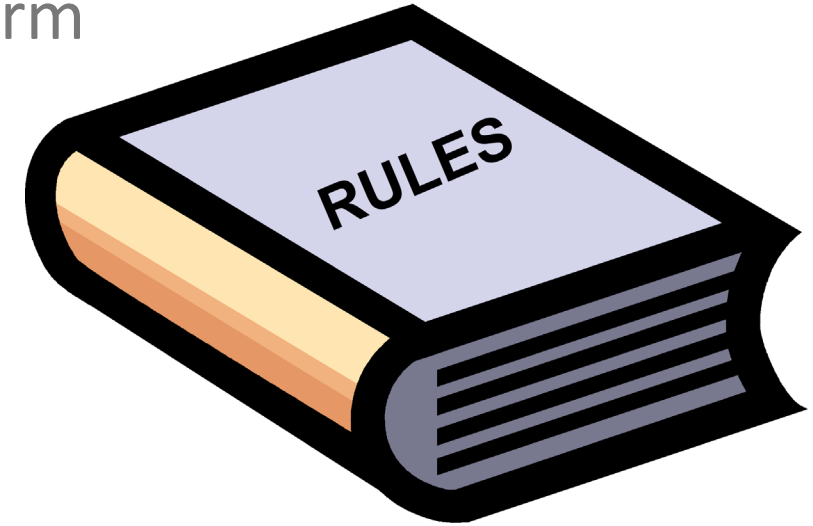
Anomaly based



- Bygger på en profil/baseline för vilken trafik som tillåts
  - Spela in tillåten eller vanlig trafik
  - **och/eller:** Ange RFC
- Kan fånga upp okända hot
- Kan ge falsklarm (blockerar allt som inte är med i profilen)
- Kan vara svår att konfigurera så den fungerar bra
- Om normal-profilen innehåller skadlig trafik eller en attack anses den vara legitim

Policy based

- Liknar *signature/pattern based*, men bygger på egna policys av trafik för vilket typ av trafik som är suspekt på nätverket snarare än fördefinerade mönster
- På sätt och vis mer lik en brandvägg
- Kan känna av okända attacker, men också ge falsklarm
- Enkla att konfigurera



Honey pot (trigger)

- En **honey pot** (allmänt begrepp) lockar till sig skadlig kod och attacker, t.ex. genom att sätta upp opatchade servrar
  - Ger möjlighet att studera hur en attack går till
  - Används t.ex. av antivirusföretag för att studera ny skadlig kod
- En **honey pot trigger** kan användas för att fånga hackers och blockera dem från nätverket
  - Används även för att distrahera och förvirra hackers
  - **Specter** är en mjukvara för detta

IPS-larm

- IPS kan ibland larma för legitim trafik, och ibland missa skadlig kod. Larm klassas därför som
  - **True positive**
    - Larm ges vid skadlig trafik
  - **True negative**
    - Inget larm vid normal trafik
  - **False positive**
    - Larm ges vid normal trafik
  - **False negative**
    - Inget larm trots skadlig trafik

Lyper av larm

True: IPS gjorde rätt
False: IPS gjorde fel

Positive: Åtgärd
Negative: Ej åtgärd

A B

Ex: ”True Negative”

”IPS:en gjorde rätt, för den slängde inte paketet”

Åtgärd vid larm från IPS

- Åtgärd kan vara en eller en kombination av följande:
  - Generera larm
  - Logga till server
  - Kasta paketet/paketen
  - Reseta TCP-sessioner
  - Blockera framtida åtkomst
    - Möjligen med tidsbegränsning
  - Tillåta paket att släppas igenom

Alerts

- **Atomic alerts**
  - Enskilda alerts för varje larm
  - Kan bli överväldigande
- **Summary alerts**
  - Summerar alerts så man som säkerhetsansvarig inte har lika mycket jobb med att granska loggarna
  - Ofta genereras ett paket i början av en attack, och en i slutet
- Fördelar/nackdelar?

Logging

```
%IPS-4-SIGNATURE:Sig:1107 Subsig:0 Sev:2 RFC1918 address
[192.168.121.1:137 -> 192.168.121.255:137]
```

- Vid larm kan loggning ske via
  - Konsol
  - Syslog
  - SDEE – Security Device Event Exchange
    - Måste aktivera http-server
- En modern lösning rapporterar ofta mot ett SIEM (Security information and event management)

Cisco IOS IPS

- IPS-funktionalitet i Cisco-router
  - Kräver ISR G2-routrar, dvs C1900, C2900 och C3900-serien, enligt materialet
    - Det är fel. Det går att köra på äldre saker, som 7200, 2800, 1800 och 800-routrar
  - I stort sett utfasat
- Signaturbaserat
  - Atomic (per paket)
  - Composite (per mönster i paket)

Snort

Snort

- Snort är baserad på öppen källkod och kan köras på:
  - På en fysisk eller virtuell server (Linux-baserad)
  - Som hårdvaruappliance, t.ex. via ASA eller Firepower
- Snort skapades 1998 av Martin Roesch, grundare till företaget Sourcefire
- Sourcefire köptes upp 2013 av Cisco

Snort-regler

- Hittas i **/etc/snort/rules/**
- Filen **local.rules** är till för egna regler

Protokoll

Destination IP/Port

Regelalternativ, t.ex. Meddelande, unikt ID och revisionsnummer

Åtgärd

Source IP/Port

```
alert TCP any any -> any any (msg:"TCP Packet found"; sid:1000001; rev:1;)
```

Åtgärder i Snort-regler

- **alert:** Genererar en notis och loggar
- **log:** Loggar paketet
- **pass:** Ignorerar paketet
- **activate:** Generar notis och sätter igång en dynamisk regel
- **drop:** Blockerar och loggar paketet
- **reject:** Blockerar paketet, loggar, och skickar *TCP reset* eller *ICMP unreachable*
- **sdrop:** Blockerar, men loggar inte

Enkel HTTP-regel

alert tcp any any -> any 80 (**msg**: “Possible HTTP GET request”; **content**: “GET”; **http_method**; **content**: “example.com”; **http_host**; **sid**:1000001; **rev**:1;)

Avancerad HTTP-regel

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (**msg**:"SERVER-WEBAPP Western Digital MyCloud command injection attempt"; **flow:**to_server,established; **content:**"/web/google_analytics.php"; **fast_pattern:**only; http_uri; **content:**"cmd=set"; nocase; http_client_body; **content:**"arg="; nocase; http_client_body; **content:**"isAdmin=1"; nocase; http_cookie; **content:**"username=admin"; nocase; http_cookie; **content:**"local_login=1"; nocase; http_cookie; **pcre:**"/(^|&)arg=[^&]*?([\x60\x3b\x7c]|\x24\x28|%60|%3b|%7c|%26|%24%28)/Pim"; **metadata:**policy max-detect-ips drop, policy security-ips drop, ruleset community, service http; **reference:**cve,2016-10108; **classtype:**web-application-attack; **sid:**41348; **rev:**3;)

Regelalternativ

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (**msg**:"SERVER-WEBAPP Western Digital MyCloud command injection attempt"; **flow**:to_server,established; **content**:"/web/google_analytics.php"; **fast_pattern**:only; http_uri; **content**:"cmd=set"; nocase; http_client_body; **content**:"arg="; nocase; http_client_body; **content**:"isAdmin=1"; nocase; http_cookie; **content**:"username=admin"; nocase; http_cookie; **content**:"local_login=1"; nocase; http_cookie; **pcre**:"/(^|&)arg=[^&]*?([\x60\x3b\x7c]|\x24\x28|%60|%3b|%7c|%26|%24%28)/Pim"; **metadata**:policy max-detect-ips drop, policy security-ips drop, ruleset community, service http; **reference**:cve,2016-10108; **classtype**:web-application-attack; **sid**:41348; **rev**:3;)

Förklara en Snort-regel med AI

Färdiga regler

- Det finns tre alternativ för färdiga regler i Snort:
  - **Subscribers** – Kräver ett abonnemang från Cisco, uppdateras normalt minst två gånger i veckan
  - **Community** – Fria att ladda ned, drivs via ett community, ofta baserade på registrerade regler, ligger minst 30 dagar efter

Tillägg

- **BASE** – Grafiskt gränssnitt för Snort
- **Snorby** – Alternativ till BASE
- **PulledPork** – Håller attacksignaturer uppdaterade automatiskt (antingen via *Subscribers* eller *Community*)

Labben

kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering